

WEB APPLICATION

PENETRATION TEST REPORT

Target	https://intra.cbi-platform.com
IP Address	159.138.253.91
Stack	WAR/Java + Apache Tomcat + Nginx + MySQL
Scan Start	2026-06-03 00:17:51
Scan End	2026-06-03 00:27:20
Tester	kali@kali
Toolkit	WebPentest Toolkit v2.2.1
Report Date	2026-06-03

OVERALL RISK	INFORMATIONAL
--------------	---------------

Executive Summary

A web application penetration test was conducted against the target stack (WAR/Java + Apache Tomcat + Nginx + MySQL). No Critical, High, Medium, or Low severity vulnerabilities were identified. The server demonstrates a well-hardened TLS configuration (Grade A+), proper security headers, no exposed administrative interfaces, and correctly disabled legacy protocols. One informational finding was recorded requiring out-of-band verification for Log4Shell (CVE-2021-44228).

Severity	Count
■ Critical	0
■ High	0
■ Medium	0
■ Low	0
■ Info	1
Total	1

Security Controls — Passed Checks

Control	Result	Status
TLS 1.0	not offered	■ PASS
TLS 1.1	not offered	■ PASS
SSLv2 / SSLv3	not offered	■ PASS
HTTP Request Smuggling	server rejects malformed TE header	■ PASS
Spring4Shell indicators	none in response	■ PASS
Struts2 RCE indicators	none in response	■ PASS
MySQL port 3306	not publicly accessible	■ PASS
Tomcat Manager	not accessible externally	■ PASS
TLS Grade (testssl)	A+	■ PASS
HSTS	enabled — 365 days incl. subdomains + preload	■ PASS
X-Frame-Options	SAMEORIGIN	■ PASS
Content-Security-Policy	present	■ PASS
OCSP Heartbleed / ROBOT / POODLE	not vulnerable	■ PASS

Detailed Findings

Finding #1 ■ INFO

CVE-2021-44228

Log4Shell Payloads Sent — Out-of-Band Verification Required

CVSS: 10.0 (if confirmed)

Component: Java Logging / Log4j

Description
JNDI injection payloads were sent via HTTP headers (X-Forwarded-For, User-Agent, Referer, X-API-Version) and POST parameters. No in-band response confirms exploitation; DNS/HTTP callback verification is required to confirm vulnerability.

Potential Impact
If confirmed: unauthenticated Remote Code Execution on the server. Log4j versions 2.0-beta9 through 2.14.1 are affected.

- Remediation**
- Upgrade Log4j to >= 2.17.1 (Java 8), >= 2.12.4 (Java 7), or >= 2.3.2 (Java 6)
 - Set JVM flag: -Dlog4j2.formatMsgNoLookups=true as temporary mitigation
 - Use Burp Collaborator or interactsh-client to verify OOB callbacks
 - Run: interactsh-client -v and re-test all endpoints

Manual Verification Command

```
interactsh-client -v # Re-run with INTERACTSH_URL set in the toolkit
```

CVEs — Manual Verification Required

The following CVEs were not confirmed vulnerable during automated scanning but should be manually verified given the target stack (WAR/Java + Tomcat + Nginx + MySQL).

CVE	Description	Priority
CVE-2020-1938	Ghostcat — AJP port 8009 file inclusion	HIGH
CVE-2021-44228	Log4Shell — JNDI RCE via Log4j (OOB check required)	HIGH
CVE-2022-22965	Spring4Shell — Spring Framework RCE on JDK9+	HIGH
CVE-2017-12617	Tomcat PUT method RCE	MEDIUM
CVE-2017-5638	Apache Struts2 OGNL RCE (S2-045)	MEDIUM

Appendix A — TLS/SSL Configuration Detail

Check	Result	Status
SSLv2	not offered	OK
SSLv3	not offered	OK
TLS 1.0	not offered	OK
TLS 1.1	not offered	OK
TLS 1.2	offered	OK
TLS 1.3	offered	OK
ALPN	http/1.1	OK
HSTS	365 days, includeSubDomains, preload	OK
Forward Secrecy	offered (ECDHE + DHE)	OK
LUCKY13 (CBC ciphers)	potentially vulnerable — CBC ciphers enabled in TLS 1.2	NOTE
Heartbleed	not vulnerable	OK
ROBOT	not vulnerable	OK
POODLE	not vulnerable	OK
BEAST	not vulnerable	OK
LOGJAM	not vulnerable	OK
SWEET32	not vulnerable	OK
Overall Grade (testssl)	A+	OK

Note — LUCKY13 (CBC ciphers): TLS 1.2 currently offers CBC-mode cipher suites (e.g. ECDHE-RSA-AES256-SHA384, ECDHE-RSA-AES128-SHA256). While testssl flags this as 'potentially vulnerable', practical exploitation requires a Man-in-the-Middle position and many millions of requests. Recommend disabling CBC suites and preferring AEAD-only (GCM/ChaCha20) in the Nginx `ssl_ciphers` directive.